Single Sign-On with SAML and OIDC

Project: *Okta Identity Lab |* ***Author:*** *Ismayeel Khan |* ***Date:*** *October 25, 2026 |* ***Environment:*** *Okta Integrator Free Plan*

---

1. Goal

The goal of this checkpoint was to connect apps to Okta, assign them by group, and test who gets in and who gets blocked.

2. What is Single Sign-On?

Single Sign-On (SSO) means a user signs in to Okta once, and Okta lets them into every app assigned to them. They do not need a separate password for each app.

Two roles are involved:

- **Identity Provider (IdP):** the system that checks "who are you?" Here, that is Okta.
- **Service Provider (SP):** the app that trusts the IdP's answer.

The IdP and the app talk to each other using a standard "language." I worked with two of them:

- **SAML 2.0:** an older, very common standard used by many business apps.
- **OIDC (OpenID Connect):** a newer standard built on OAuth, common in modern web apps.

3. The Plan

I created three apps and assigned each to a different group, so I could prove that access follows the group.

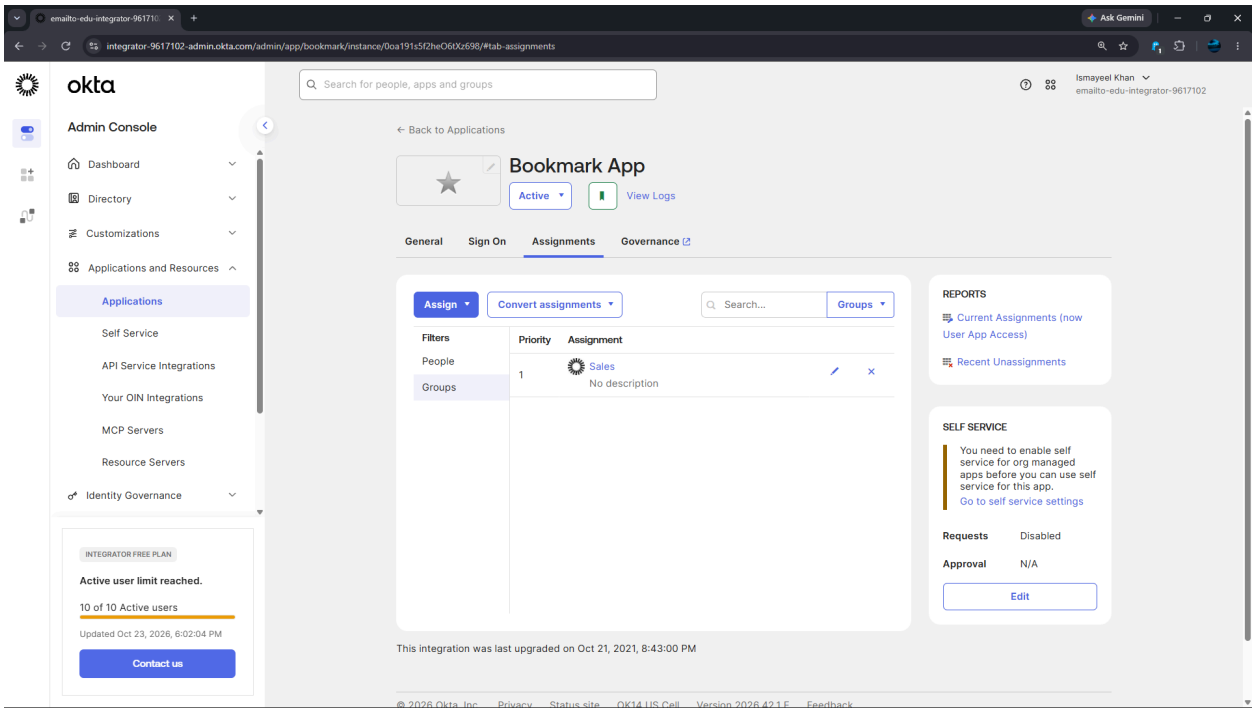
App	Type	Assigned to	How I tested it
Bookmark App	Bookmark (a simple link)	Sales	Checked a Sales user's dashboard
SAML Test App	SAML 2.0	IT	Tried a third-party SAML test site

App	Type	Assigned to	How I tested it
OIDC Test App	OIDC (single-page app)	IT	Signed in through an OIDC debugger

4. App 1: Bookmark App

I added a **Bookmark App** from the app catalog and assigned it to the **Sales** group. A bookmark app is just a link on the user's dashboard. Okta does not sign the user in to anything, but it still shows how app assignment works.

I left the default name "Bookmark App." I renamed it Company Wiki in Checkpoint 4.



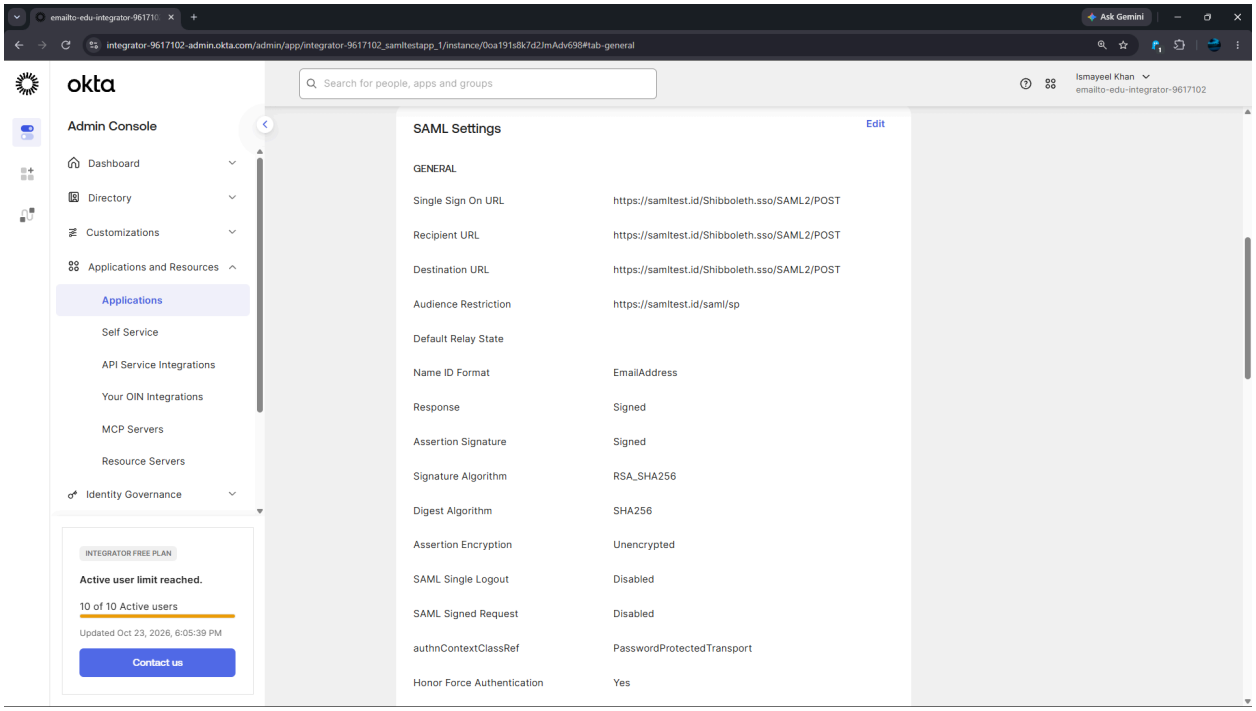
Bookmark App assigned to the Sales group.

5. App 2: SAML Test App

Next I created a custom **SAML 2.0** app. I used the settings of a public SAML test site (samltest.id) so I would not need a paid app or a real company account:

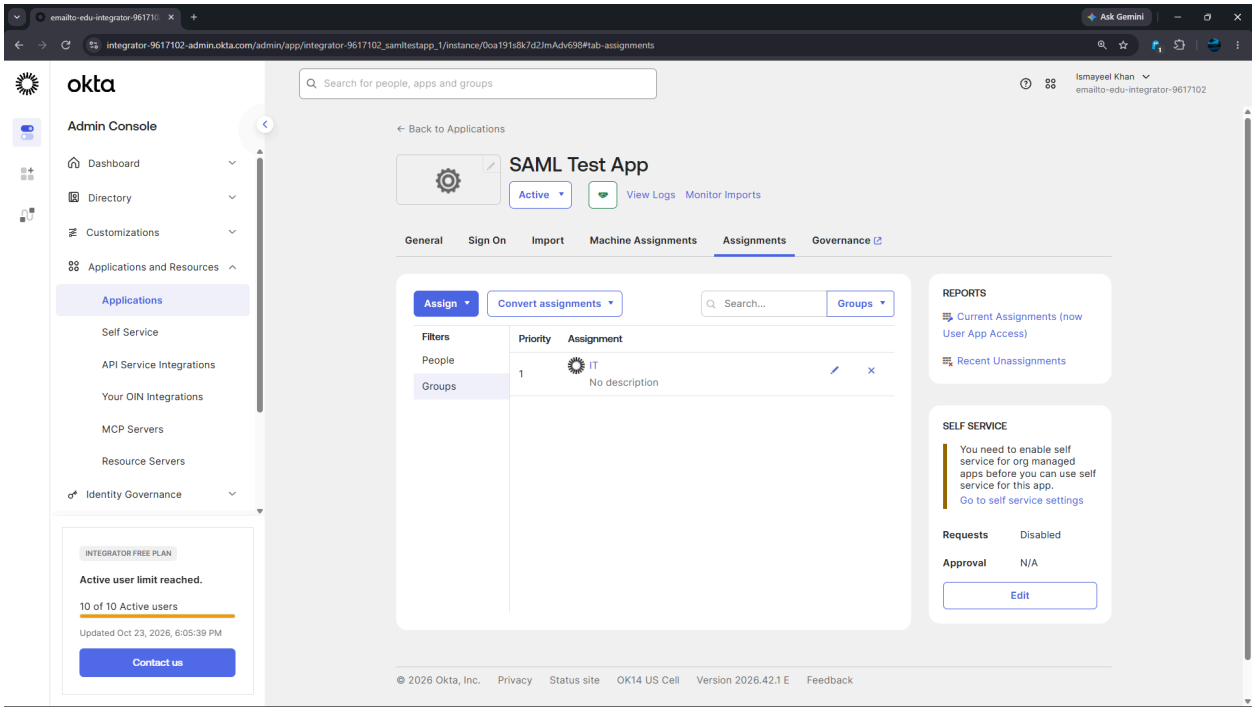
- **Single sign-on URL:** the test site's SAML endpoint
- **Audience URI:** the test site's service provider ID
- **Name ID format:** EmailAddress
- **Application username:** Email

Okta signs both the response and the assertion, using RSA-SHA256.



SAML Test App settings.

I then assigned the app to the **IT** group.



SAML Test App assigned to the IT group.

The SAML test did not work

To finish a SAML setup, I downloaded Okta's metadata and uploaded it to the test site so the two sides could trust each other. I could not get the third-party test site to complete the login test.

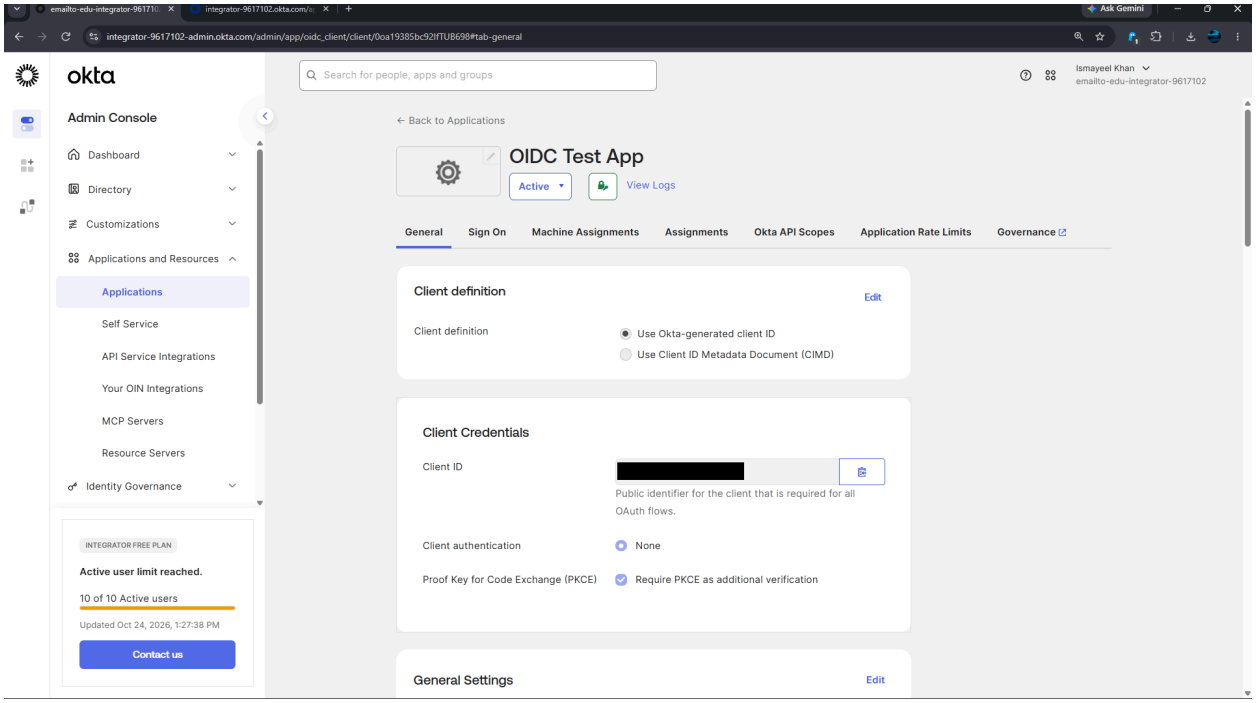
Because I could not confirm a successful SAML sign-in, **I am not claiming that SAML SSO worked in this lab.** The SAML app is configured and assigned correctly, and it appears on the right users' dashboards, but the full login was not verified. Instead of getting stuck, I switched to a different protocol that I could test.

6. App 3: OIDC Test App

I created an **OIDC single-page app** and limited access to the **IT** group. The key settings:

- **Sign-in redirect URI:** the OIDC debugger site
- **Flow:** Authorization Code with **PKCE** required
- **Access:** only the IT group

PKCE is an extra safeguard for apps that cannot keep a secret. The app proves it is the same one that started the login.



OIDC Test App settings, with PKCE required.

7. Testing the OIDC App

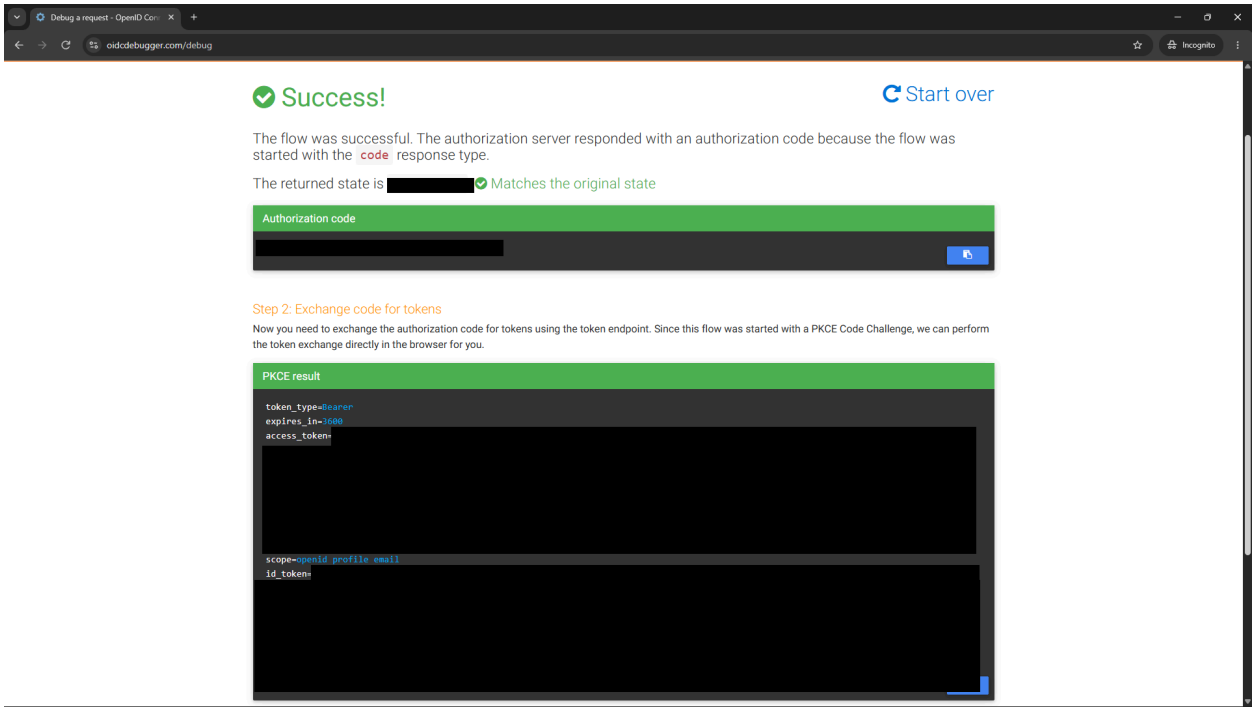
I used a free OIDC debugger website as the "app." I entered my org's authorization address and the app's client ID, asked for the `openid profile email` scopes, used the `code` response type, and turned PKCE on.

I ran every test in a **private (incognito) window**. If I had used my normal browser, Okta would have recognized my admin session instead of the test user.

Test 1: an IT user (Rohan Mehta)

Rohan is in the IT group. He signed in, Okta checked his group, and the debugger returned **Success**:

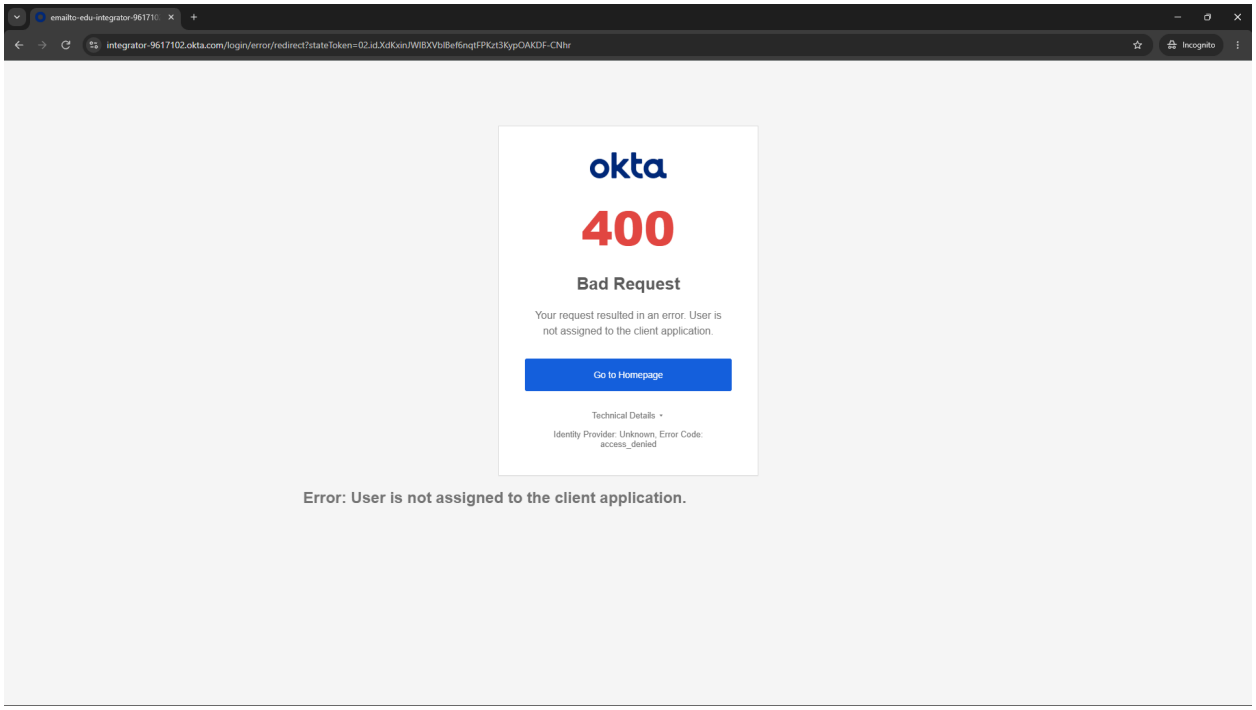
- an **authorization code**, which means Okta approved the sign-in
- an **access token** and an **ID token**, which are digital proof of who he is and what he can access (they expire after one hour)



OIDC debugger showing Success for an IT user. (Code and tokens blurred.)

Test 2: a Sales user (Neha Singh)

Neha is in Sales, and the OIDC app is assigned only to IT. Okta blocked her with **400 Bad Request: "User is not assigned to the client application"** (error code `access_denied`).

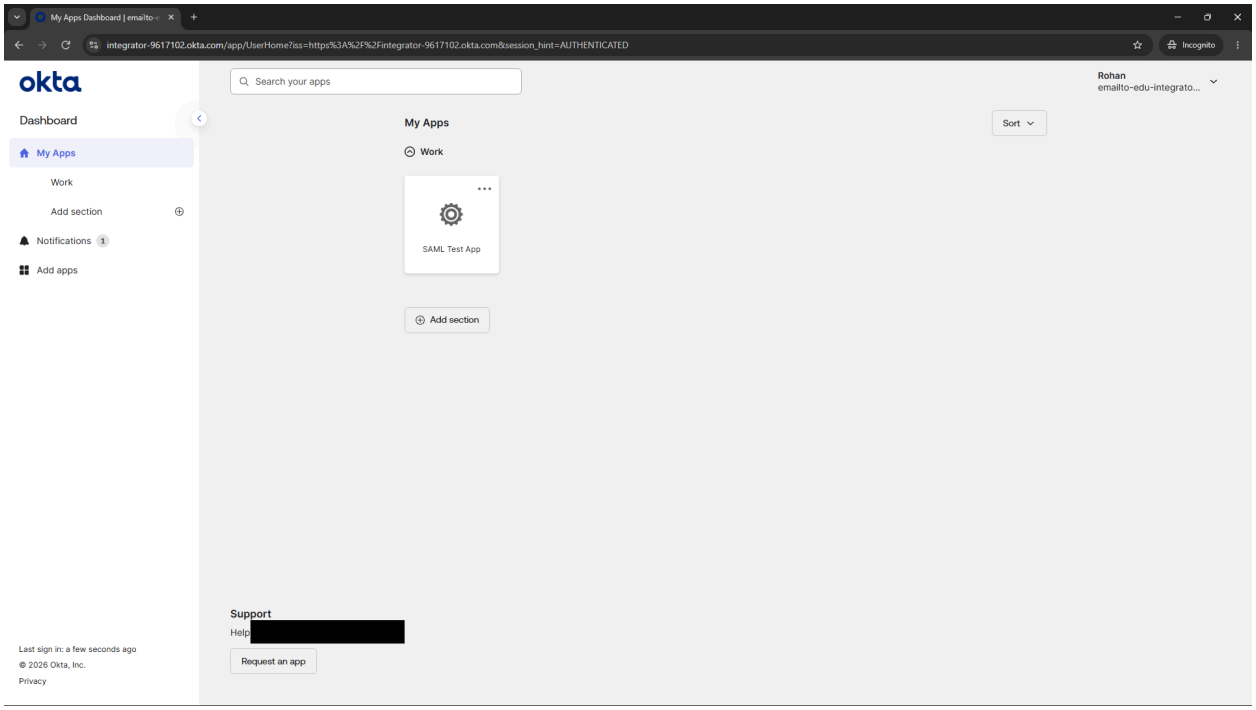


Neha is blocked because she is not in the IT group.

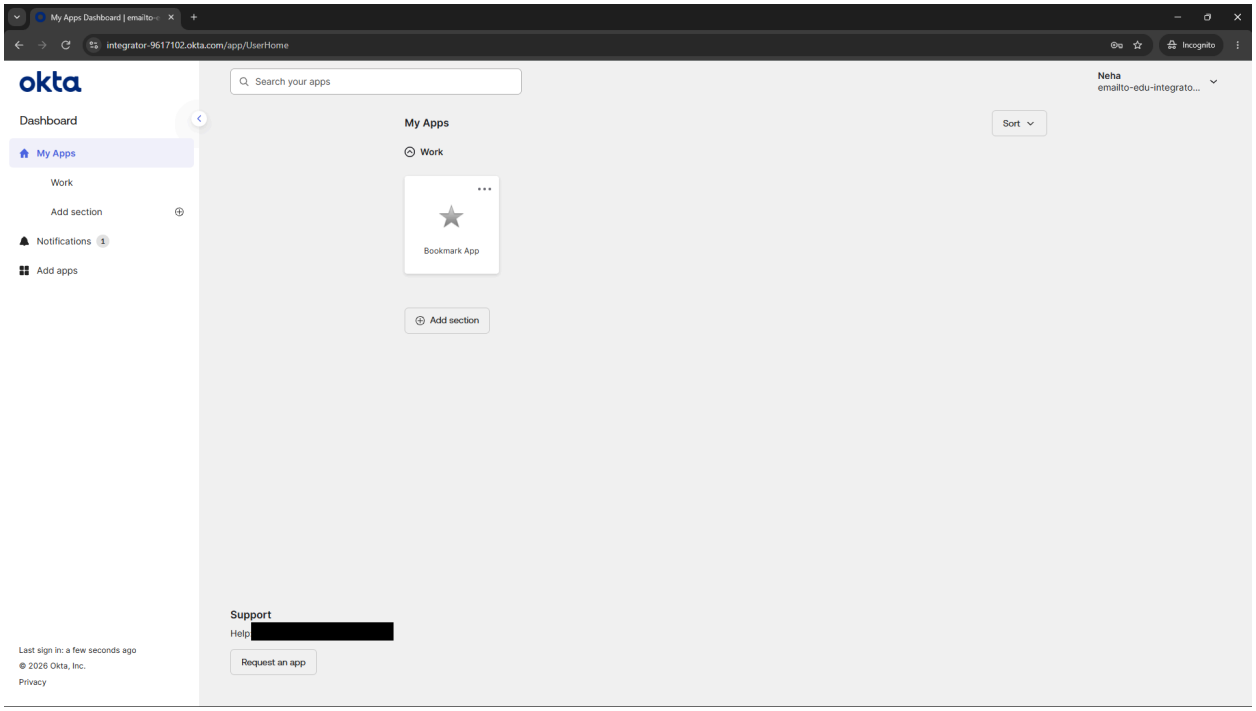
The same app gave one user access and blocked another. The only difference was their group.

8. What Each User Sees

I also signed in to the normal Okta Dashboard as each user to see which app tiles they get.



Rohan (IT) sees the SAML Test App.

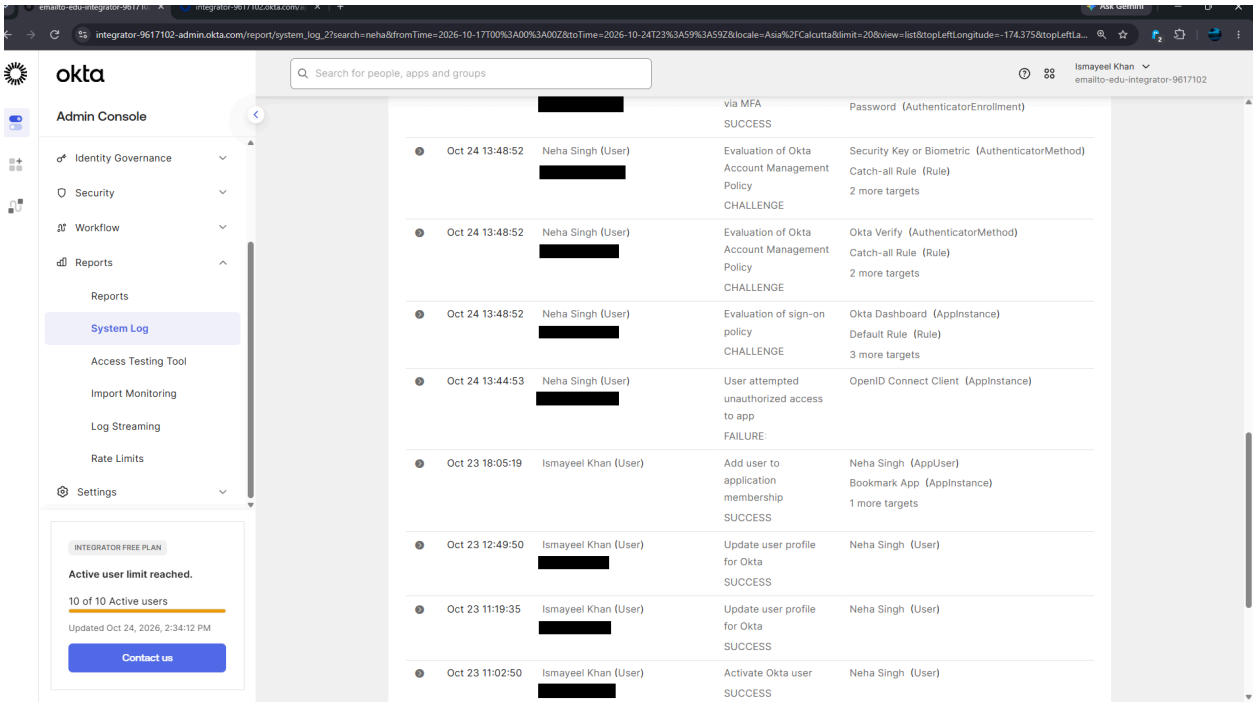


Neha (Sales) sees the Bookmark App.

Each person sees only the apps their group gets.

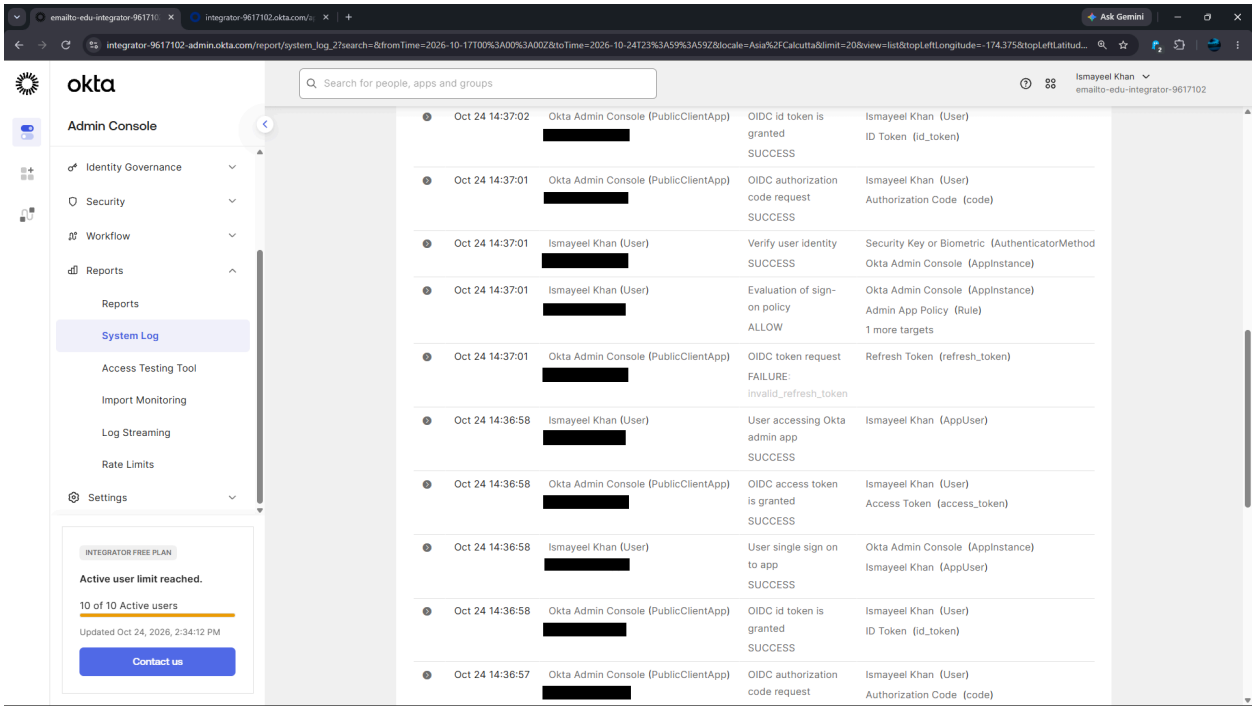
9. Evidence in the System Log

I checked the log for Neha's blocked attempt. It shows **"User attempted unauthorized access to app"** with the result **FAILURE**, against the OIDC app.



System Log entry for Neha's blocked attempt. (IP addresses blacked out.)

I also looked at how Okta protects its own admin console. My own admin sign-in shows the sequence: the sign-on policy **challenges** me, I prove who I am with a passkey, and then the policy **allows** access. One line shows a failed refresh token request. That looked alarming but was harmless: the console simply needed a fresh token and got one right after. Not every FAILURE is an attack.



Admin console sign-in in the System Log: challenge, verification, allow. (IP addresses blacked out.)

10. Problems I Ran Into

- **The SAML test site would not complete the login.** I used the problem as a reason to test OIDC instead, and I documented it honestly.
- **Metadata link in the new layout.** In my version of Okta, the SAML metadata appears as a URL under "Metadata details" instead of a "View IdP metadata" button.
- **Admin session got in the way.** Testing in my normal browser would have used my admin login, so I used incognito windows for every user test.

11. Key Concepts I Learned

- **SSO:** one login, many apps.
- **IdP vs. SP:** Okta decides who you are, and the app trusts it.
- **SAML vs. OIDC:** two standards for the same job.
- **Authorization code and tokens:** the proof Okta hands back after a successful sign-in.
- **Group-based assignment:** access follows the group, so changing a group changes access.
- **Not every failure is an attack:** read the log before drawing a conclusion.

12. Limits and Notes

- **SAML login was not verified.** The app is configured and assigned, but the third-party test did not complete.
- OIDC was tested with a public debugger tool, not a real application.
- All users and apps are fake and used only for testing.

13. What I Learned and What Is Next

The main lesson from this checkpoint: **assign apps to groups, not people.** One group change gives or removes access to everything that group uses.

Next, in Checkpoint 4, I add multi-factor authentication and sign-in policies.